

Security+ 1.4 · Hashing & Digital Signatures

Master CyberSec — Official CompTIA Security+ (SY0-701) Comprehensive Study Guide · **Lesson 1.4** — Hashing & Digital Signatures (10:24) · [Official YouTube Video ↗](#) · [Professor Messer Study Hub ↗](#)

Executive Lesson Summary: A hash is a one-way fingerprint: SHA-256/SHA-3 are the current standards, while MD5/SHA-1 are broken due to collision vulnerabilities. A digital signature is created by encrypting the hash with the signer's PRIVATE key; anyone can validate it using the corresponding public key. This provides integrity, authenticity, and non-repudiation (three security objectives).

High-Yield Core Concepts Tested on Exam

- SHA-256 is the standard; MD5/SHA-1 are broken (collision attacks)
- Digital signature = hash encrypted with the signer's PRIVATE key
- Avalanche effect: a 1-bit change alters the entire hash output
- Digital signatures provide integrity, authenticity, and non-repudiation
- Hashing alone does not provide confidentiality

Exam Tips & Classic Scenarios

- 'provides integrity but not confidentiality' = hashing
- 'cannot deny that they signed' = digital signature (non-repudiation)
- If the question mentions 'verify file integrity after download' = hash (e.g., SHA-256)

Typical Exam Scenario: Scenario: 'A file is verified with SHA-256 after download to ensure it was not altered' = integrity via hashing.

Beyond the Video: Official CompTIA Exam Concepts, Protocols & Traps (Lesson 1.4 — Hashing & Digital Signatures)

Why is this advanced coverage required for SY0-701? Video overviews provide foundational familiarity, but CompTIA tests practical engineering judgment and requires deep familiarity with the following protocols, acronyms, and operational nuances in this domain:

- **Principle of Least Privilege:** Users and computational entities must be granted only the minimum permissions strictly required to perform designated tasks.
- **Defense-in-Depth (Layered Security):** Application of multiple security controls (technical, administrative, physical) to prevent single-point perimeter compromise.

Classic CompTIA Traps & Question Framing:

- Avoid rote memorization: CompTIA exam prompts regularly adjust technical constraints requiring you to defend why one valid security control is the *MOST appropriate* or *FIRST step*.
- Scrutinize question qualifiers: 'without additional licensing costs' favors native OS tools; 'granular administrative command accounting' favors TACACS+ over RADIUS; 'non-repudiation' mandates asymmetric private key signing.

Practice Questions with In-Depth Solutions (10 Questions)

Detailed answer key with step-by-step technical rationale and comprehensive distractor breakdown provided below. Attempt answering independently first.

1. To ensure a file has NOT been altered (integrity), you use:

- A) ZIP compression
- B) Hash function (e.g., SHA-256)
- C) AES encryption
- D) Base64 signature

2. A characteristic of HASH (unlike encryption) is that it:

- A) Can be reversed with the key
- B) Is one-way (not reversible)
- C) Always shortens the text by half
- D) Requires a key pair

3. The correct way to STORE user passwords:

- A)** Hash with salt (e.g., bcrypt)
- B)** Reversible AES encryption
- C)** Plaintext protected by firewall
- D)** Base64

4. Which cryptographic function is NOT reversible?

- A)** AES encryption
- B)** RSA encryption
- C)** SHA-256 hash
- D)** Base64 encoding

5. Corporate scenario (Hashing & Digital Signatures): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 1.4), an analyst evaluates the following technical requirement: 'SHA-256 standard; MD5/SHA-1 broken (collision)'. What is the best recommendation or applicable control classification?

- A)** Implement the corresponding solution: SHA-256 standard; MD5/SHA-1 broken (collision)...
- B)** Temporarily disable audit logs to accelerate system throughput
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators with generic credentials

6. Corporate scenario (Hashing & Digital Signatures): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 1.4), an analyst evaluates the following technical requirement: 'Signature = hash encrypted with the PRIVATE key of the signer'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Allow shared access among administrators with generic credentials
- D)** Implement the corresponding solution: Signature = hash encrypted with the PRIVATE key of the signer...

7. Corporate scenario (Hashing & Digital Signatures): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 1.4), an analyst evaluates the following technical requirement: 'Avalanche effect: 1 bit changed = entire hash changed'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Implement the corresponding solution: Avalanche effect: 1 bit changed = entire hash changed
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators with generic credentials

8. Corporate scenario (Hashing & Digital Signatures): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 1.4), an analyst evaluates the following technical requirement: 'provides integrity but not confidentiality' = hash. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Implement the corresponding solution: 'provides integrity but not confidentiality' = hash...
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators using generic credentials

9. Corporate scenario (Hashing & Digital Signatures): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 1.4), an analyst evaluates the following technical requirement: 'cannot deny that they signed' = digital signature (non-repudiation). What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Allow shared access among administrators using generic credentials
- D)** Implement the corresponding solution: 'cannot deny that they signed' = digital signature (non-repudiation)...

10. Corporate scenario (Hashing & Digital Signatures): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 1.4), an analyst evaluates the following technical requirement: 'Scenario: file is verified with SHA-256 after download to trust it was not altered' = integrity via hash. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Implement the corresponding solution: Scenario: file is verified with SHA-256 after download to trust it was not altered...
- D)** Allow shared access among administrators with generic credentials

COMPREHENSIVE ANSWER KEY & DISTRACTOR BREAKDOWN

1) B — Hash function (e.g., SHA-256).

✓ **Why it's correct:** To ensure file integrity—i.e., to verify that it has not been altered—a cryptographic hash function such as SHA-256 is used. A hash function generates a fixed-size digest from input data. Any minimal change in the file produces a completely different hash (avalanche effect). By comparing the hash calculated before and after transmission or storage, modifications can be detected. SHA-256 is widely recommended by NIST and CompTIA Security+ for integrity verification because it is resistant to collisions and preimage attacks. Integrity is one of the pillars of the CIA triad, and hashing is the standard mechanism to verify it.

✗ **Why the others are wrong:**

- *ZIP compression:* ZIP compression reduces file size by grouping files into a container. It does not provide integrity guarantees because it does not generate a cryptographic digest to detect changes. A ZIP file can be modified without any intrinsic verification mechanism. Although the ZIP format supports CRC-32 for accidental error detection, this is a non-cryptographic checksum vulnerable to malicious alteration. Therefore, ZIP does not meet the strong integrity requirement.
- *AES encryption:* AES (Advanced Encryption Standard) is a symmetric cipher used for confidentiality, not integrity. It transforms plaintext into ciphertext but does not provide a direct means to verify if data was altered. If an attacker modifies the ciphertext, decryption may produce incorrect plaintext or fail, but without an authentication mechanism (such as HMAC or GCM mode), there is no guarantee of detection. AES alone is not a hash function and does not produce an integrity digest. For integrity, a hash or message authentication code (MAC) is required.
- *Base64 signature:* Base64 is an encoding scheme that represents binary data in ASCII text, used for transport in protocols like email (MIME). It is not a digital signature nor an integrity mechanism. Base64 provides no guarantee that content has not been altered; it is merely a reversible transformation. The term 'Base64 signature' is a misnomer, as digital signatures involve asymmetric cryptography and hash functions. Therefore, Base64 does not serve to verify integrity.

2) B — Is one-way (not reversible).

✓ **Why it is correct:** A fundamental characteristic of cryptographic hash functions is that they are one-way, i.e., not reversible. This means that from the hash, it is not possible to recover the original message. This property is known as pre-image resistance. Unlike encryption, which is reversible with the correct key, hashing is designed to be irreversible. CompTIA Security+ highlights that hash functions like SHA-256 are used for integrity and password storage (with salt), precisely because they cannot be reversed. The option 'Is one-way (not reversible)' correctly describes this essential characteristic.

✗ **Why the others are wrong:**

- *Can be reversed with the key:* This is a characteristic of symmetric or asymmetric encryption, not hash functions. In encryption, reversal is possible with the appropriate key (symmetric) or with the private key (asymmetric). Hash functions have no key and are not designed for reversal. Therefore, this statement is incorrect for hash. CompTIA Security+ emphasizes that hash is one-way and does not use keys, unlike cipher.
- *Always shortens the text by half:* Hash functions produce a fixed-size output regardless of input size. For example, SHA-256 always generates 256 bits (32 bytes). There is no 'shorten by half' rule; the digest size is constant and defined by the algorithm. Moreover, the hash function is not simple compression; it must be resistant to collisions and pre-image. This statement is technically false and does not describe a hash property.
- *Requires a key pair:* Hash functions do not use keys. They are public and deterministic algorithms

that map input data to a digest. The use of a key pair is characteristic of asymmetric encryption (such as RSA or ECC), not hash. Although hashes can be used together with keys in HMAC, the hash function itself does not require keys. Therefore, this option is incorrect.

3) A — Hash with salt (e.g., bcrypt).

✅ **Why it is correct:** Secure storage of user passwords requires the use of slow cryptographic hash functions resistant to brute-force attacks, such as bcrypt, scrypt, or Argon2, combined with a unique random salt per user. The salt prevents precomputed table attacks (rainbow tables) and ensures that identical passwords produce different hashes. Functions like bcrypt are designed to be computationally expensive, adjustable by cost factor, making dictionary and offline brute-force attacks difficult. The hash is one-way, so even if the database is compromised, the attacker does not directly obtain the original password, only the hash, which must be cracked individually.

❌ **Why the others are wrong:**

- *Reversible AES encryption:* AES is a reversible symmetric cipher: with the correct key, the ciphertext can be decrypted back to plaintext. If passwords are stored encrypted with AES, anyone who obtains the encryption key (e.g., through compromise of the application server or database) can recover all original passwords. This violates the principle that not even system administrators should know user passwords. Additionally, AES key management adds unnecessary complexity and risk for data that never needs to be recovered in plaintext.
- *Plaintext protected by firewall:* Storing passwords in plaintext means they are readable in the database or configuration file. A firewall protects against unauthorized network access but does not prevent an attacker who exploits an application vulnerability, a malicious insider, or an administrator with database access from directly reading the passwords. Defense in depth requires that sensitive data be protected at rest, regardless of perimeter controls. A firewall is a network control, not a credential storage control.
- *Base64:* Base64 is a reversible encoding without a key, often used to represent binary data in text. It offers no confidentiality: anyone can decode a Base64 string instantly. Storing passwords in Base64 is functionally equivalent to storing them in plaintext, just with an obfuscated appearance. There is no salt, no computational cost, and no resistance to attacks. It is a completely inadequate practice for credential protection.

4) C — SHA-256 hash.

✅ **Why it's correct:** The correct answer is 'SHA-256 hash'. Cryptographic hash functions like SHA-256 are designed to be one-way (non-reversible). They produce a fixed-size digest (256 bits for SHA-256) from an input of any size. There is no secret key, and there is no practical way to reverse the hash to obtain the original message, except through brute-force attacks or precomputed tables, which are infeasible for complex inputs. CompTIA Security+ emphasizes that hashing ensures integrity, not confidentiality, and is irreversible by design.

❌ **Why the others are wrong:**

- *AES encryption:* AES (Advanced Encryption Standard) is a reversible symmetric encryption algorithm. With the correct key, the ciphertext can be decrypted back to plaintext. Therefore, it is incorrect to say AES is not reversible; its reversibility is a fundamental feature for confidentiality.
- *RSA encryption:* RSA is a reversible asymmetric encryption algorithm. The private key allows decryption of what was encrypted with the public key (and vice versa for signatures). Thus, RSA is reversible by nature, provided the appropriate key is known. This option is incorrect because it confuses encryption with hashing.
- *Base64 encoding:* Base64 is a data encoding that represents binary in ASCII text using 64 characters. It is not encryption and is fully reversible (decoding). It offers no security, only facilitates

transport. This option is incorrect because Base64 is not a cryptographic function and is trivially reversible.

5) A — Implement the corresponding solution: SHA-256 standard; MD5/SHA-1 broken (collision)....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 1.4 (Hashing & Digital Signatures): SHA-256 standard; MD5/SHA-1 broken (collision). SHA-256 is currently considered secure for cryptographic hashing, while MD5 and SHA-1 are deprecated due to practical collision attacks, where two different inputs produce the same hash. This undermines integrity and digital signatures.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user behavior, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

6) D — Implement the corresponding solution: Signature = hash encrypted with the PRIVATE key of the signer....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 1.4 (Hashing & Digital Signatures): Signature = hash encrypted with the PRIVATE key of the signer.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

7) B — Implement the corresponding solution: Avalanche effect: 1 bit changed = entire hash changed.

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 1.4 (Hashing & Digital Signatures): Avalanche effect: 1 bit changed = entire hash changed. This property ensures that even minor changes to input produce drastically different hash outputs, enhancing integrity verification.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are

administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.

- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

8) B — Implement the corresponding solution: 'provides integrity but not confidentiality' = hash....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 1.4 (Hashing & Digital Signatures): 'provides integrity but not confidentiality' = hash. A cryptographic hash function produces a fixed-length digest that verifies data integrity but does not encrypt the data, so it does not provide confidentiality.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).

- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user conduct and do not block automated attacks, injections, or runtime malware.

- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

9) D — Implement the corresponding solution: 'cannot deny that they signed' = digital signature (non-repudiation)....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 1.4 (Hashing & Digital Signatures): 'cannot deny that they signed' = digital signature (non-repudiation). Digital signatures provide non-repudiation by using asymmetric cryptography to prove the origin and integrity of a message.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and violates compliance standards (PCI DSS, ISO 27001).

- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user behavior, and do not block automated attacks, injections, or malware at runtime.

- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

10) C — Implement the corresponding solution: Scenario: file is verified with SHA-256 after download to trust it was not altered....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 1.4 (Hashing & Digital Signatures): Scenario: 'file is verified with SHA-256 after download to trust it was not altered' = integrity via hash. Hashing produces a fixed-length digest that acts as a unique fingerprint of the data. By comparing the computed hash of the downloaded file with a trusted hash value, one can verify that the file has not been modified or corrupted during transit. SHA-256 is a cryptographic hash function that provides strong integrity assurance. This is a detective and preventive control for data integrity.

✗ Why the other options are wrong:

- *Temporarily disable audit logs to accelerate system throughput:* This directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and violates compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user behavior and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* This destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.